

FROM COMPLEXITY TO CONTROL.

Mastering IT Scoping
for SOX Compliance

Independent redesign based on
KPMG Future of SOX webcast material



YOU DON'T NEED TO CONTROL EVERYTHING.

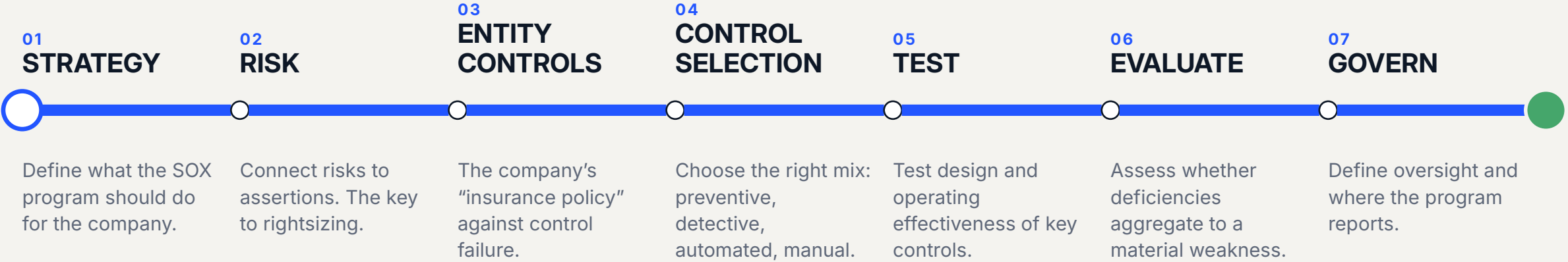
YOU NEED TO KNOW WHAT MATTERS.

A strong risk assessment establishes priorities and determines where audit effort should focus.



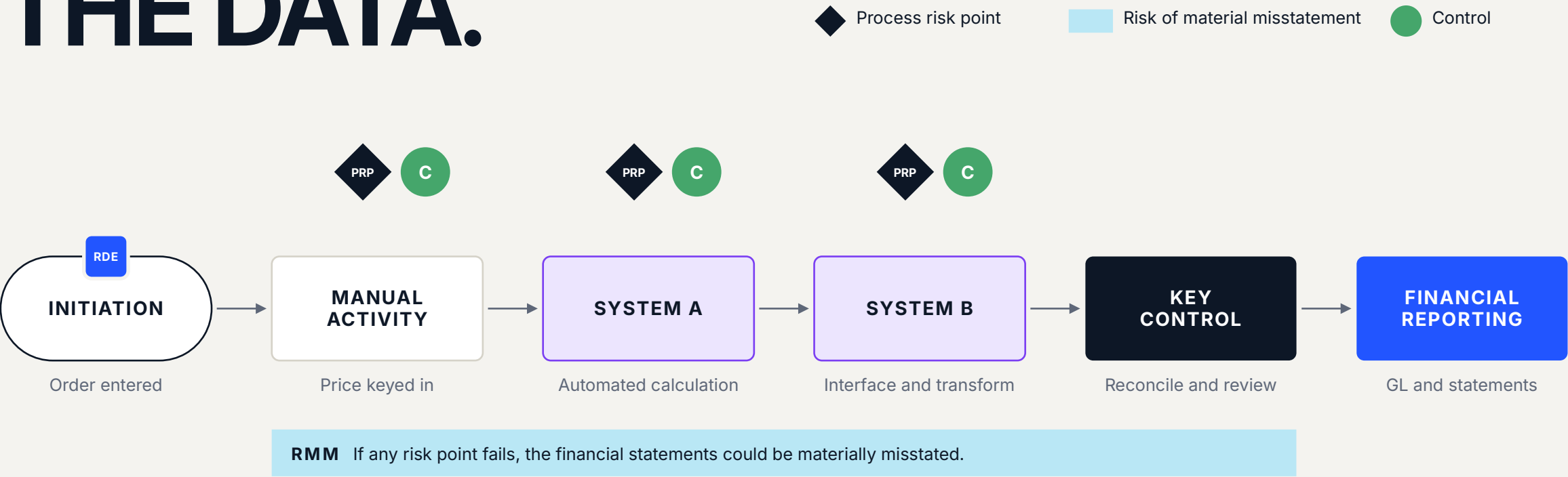
SOX IS NOT A CHECKLIST. IT IS A CONTROL SYSTEM.

Seven phases, one continuous path. Each phase depends on the one before it.



FOLLOW THE DATA.

Trace each relevant data element from its first input to the financial statements, through every manual step and automated system.



Risks sit where data changes hands. Controls sit where risk appears.

IN OR OUT?

Scope a system in when there is a clear chain of impact between it and internal control over financial reporting.

THE LITMUS TEST · FIVE QUESTIONS

YES → KEEP FOLLOWING THE CHAIN NO → NEXT TEST

01

Does it create, transform, aggregate or route financially relevant data?

YES

NO

02

Does a key control execute here, or rely on its output?

YES

NO

03

Do downstream controls depend on its data?

YES

NO

04

Could privileged access or a bad change enable a material misstatement?

YES

NO

05

Is assurance dependent on an outsourced system or SOC report?

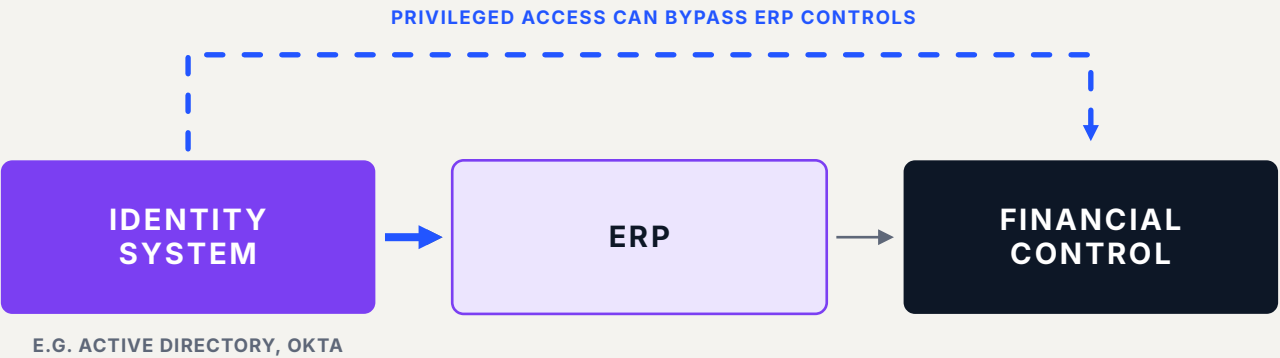
YES

NO

CLEAR CHAIN OF IMPACT
= IN SCOPE

BROKEN CHAIN OF IMPACT
= CAN BE SCOPED OUT

IT DOESN'T HOLD THE MONEY. BUT IT CAN STILL CONTROL THE RISK.



The scenario A central identity system authenticates users for nearly every application, including the in-scope ERP. It stores no dollar amounts and no financial transactions.

- 01 FINANCIAL DATA?** NO

It manages identities. It does not create, process or store invoices, journals or revenue.
- 02 KEY CONTROL EXECUTED HERE?** NO

Three-way match and segregation-of-duties checks run inside the ERP.
- 03 DOWNSTREAM CONTROL DEPENDENCY?** YES

Every ERP access control trusts the identity it authenticates. Wrong user, useless control.
- 04 PRIVILEGED ACCESS RISK?** YES

An administrator could take a finance director’s rights and approve fraudulent payments.

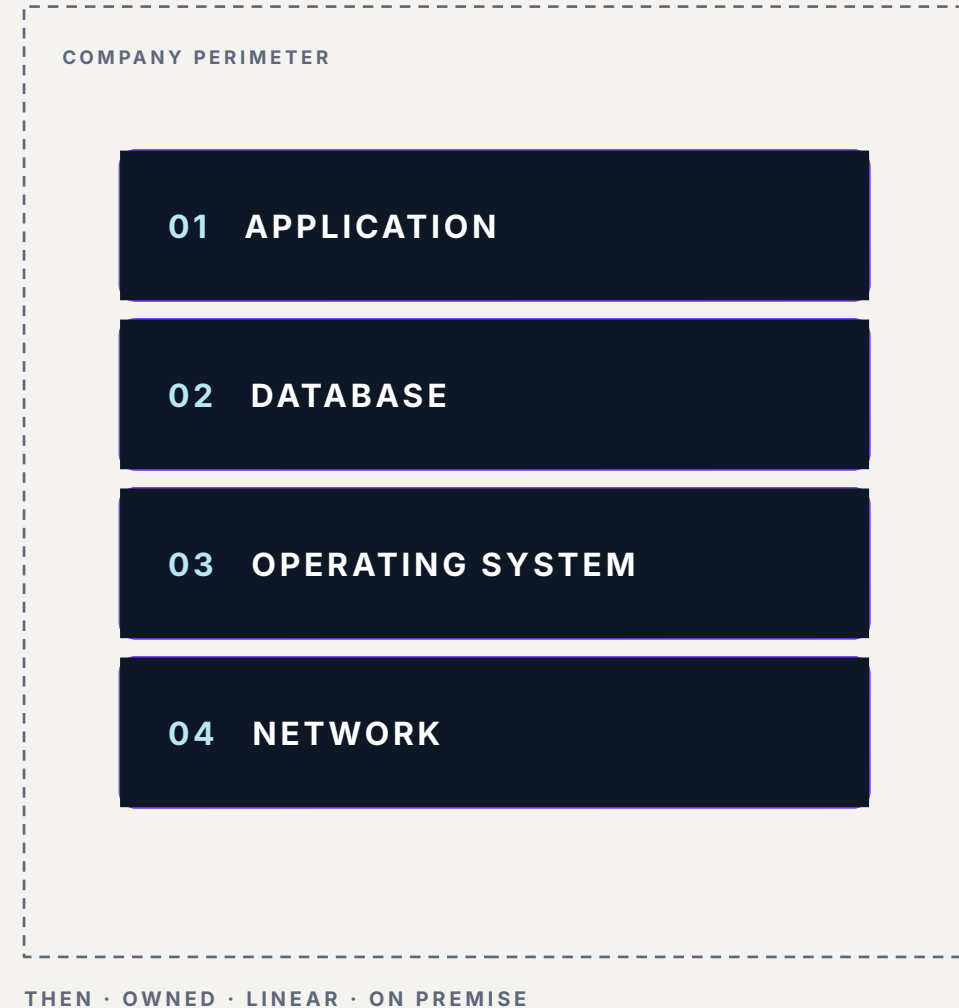
DECISION

IN SCOPE.

No financial data. But controls depend on it, and its access can bypass them.

WE USED TO AUDIT A STACK.

One owned, on-premise stack inside a well-defined company perimeter.



WE USED TO AUDIT A STACK.

NOW WE AUDIT AN ECOSYSTEM.

Responsibility is now shared with cloud and SaaS providers. Scope follows the service model: which layers are ours, and what the vendor's SOC report covers.

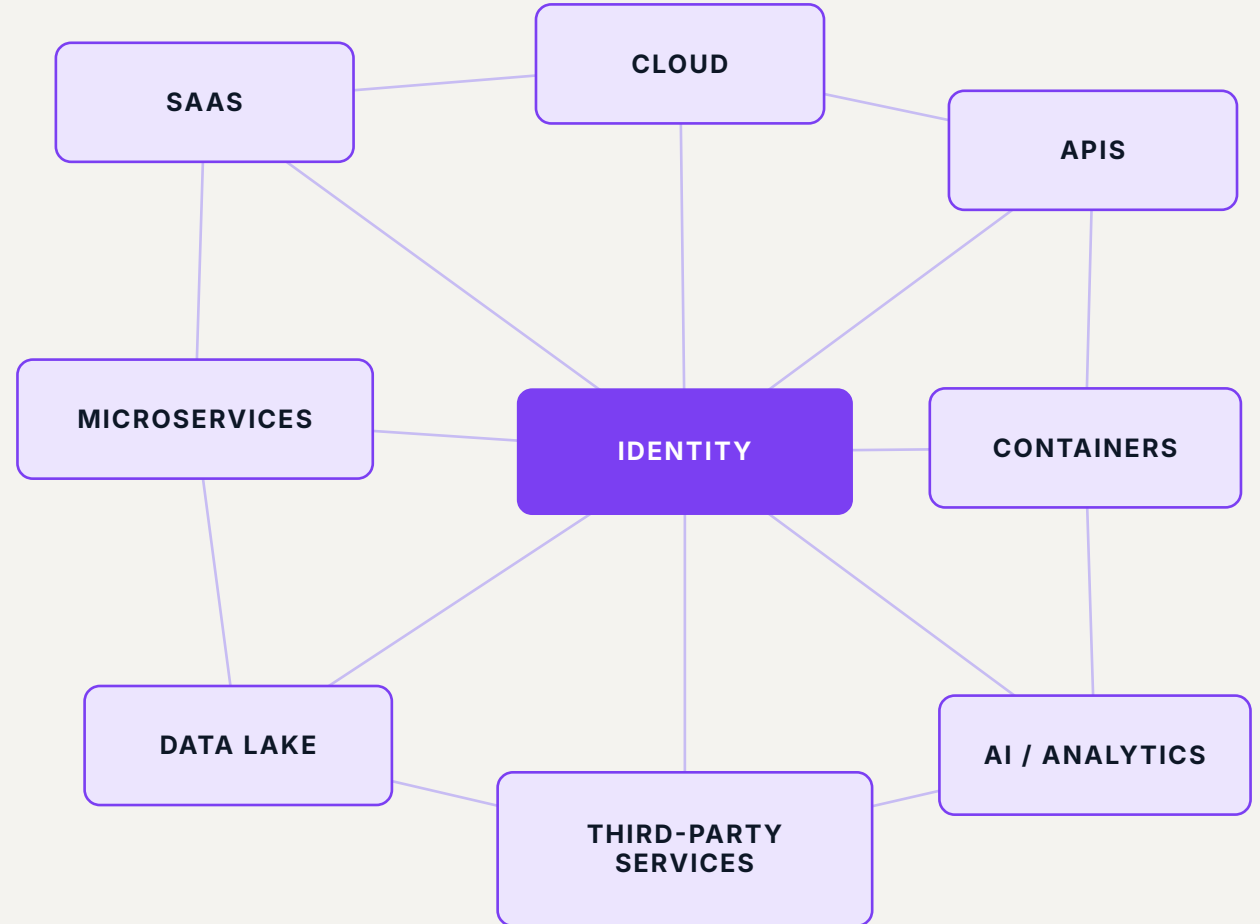
THEN

01 APPLICATION

02 DATABASE

03 OPERATING SYSTEM

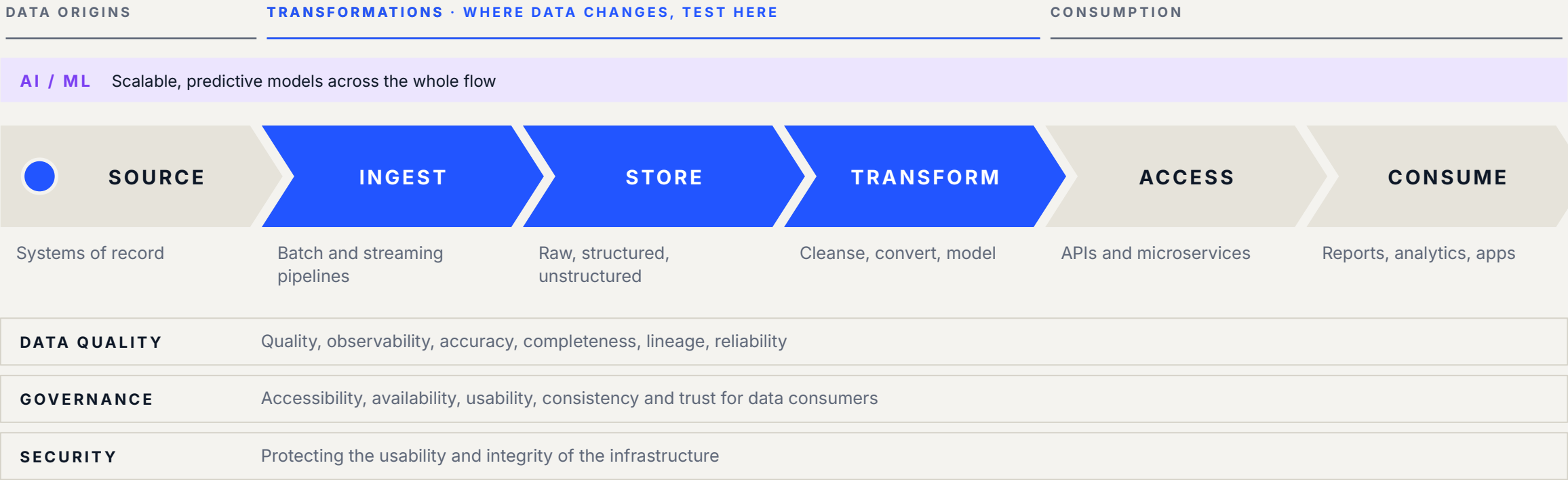
04 NETWORK



NOW · SHARED · DISTRIBUTED · SERVICE-BASED

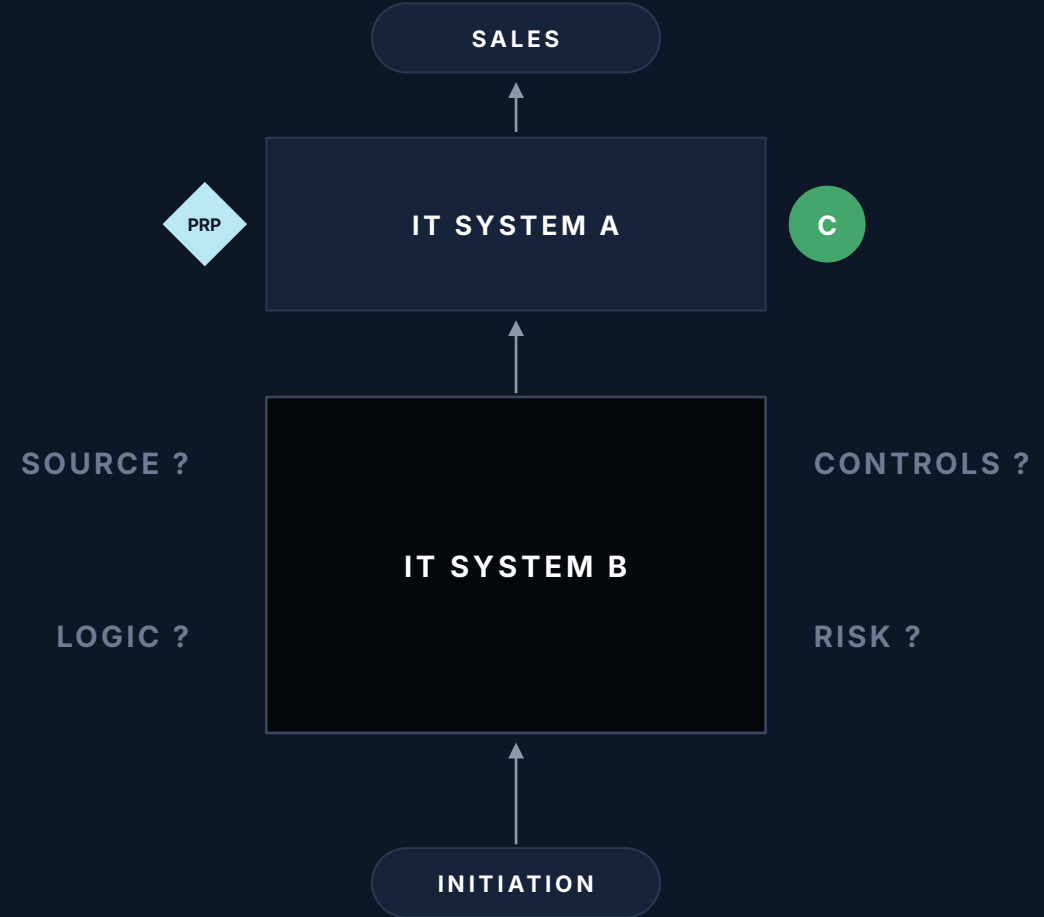
THE RISK IS IN THE JOURNEY.

SOX scoping is no longer about which applications exist. **It is about how information moves through them.**



BLACK BOX.

A common challenge: the process was mapped, but IT system B was treated as a black box.

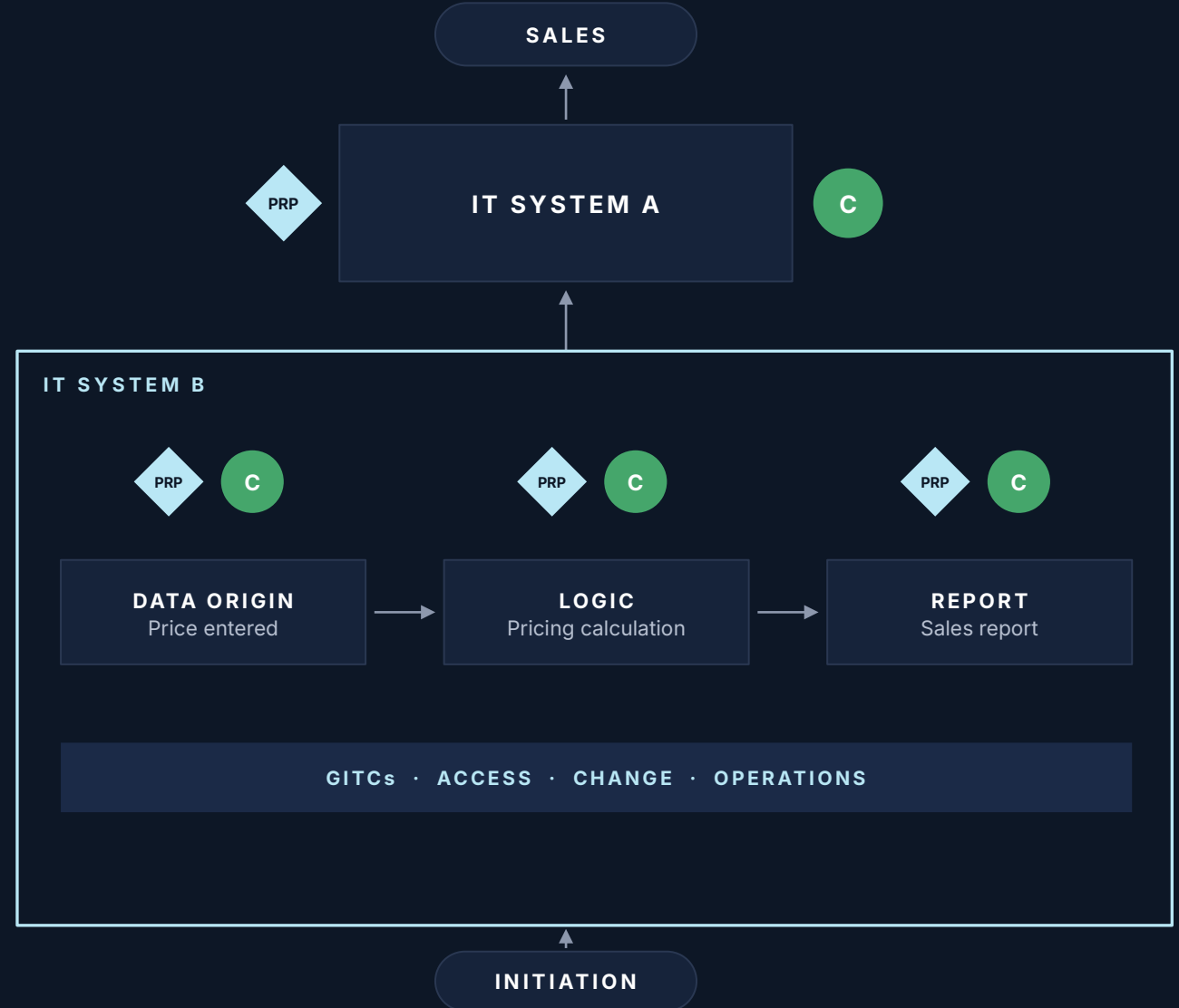


VISIBLE SYSTEM.

DON'T TREAT IT
AS A BLACK BOX.

BRING IT INTO THE WALK-THROUGH

- 01 System overview diagram
- 02 Every report and data element
- 03 Automated controls for each PRP
- 04 GITCs for the risks arising from IT



SOX SCOPING USED TO ASK:

WHAT DO WE OWN?

APPLICATION

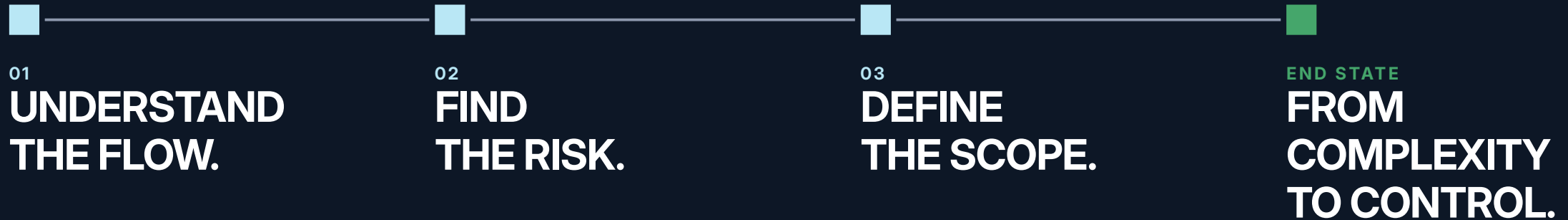
DATABASE

OPERATING SYSTEM

NETWORK

NOW IT ASKS:

HOW DOES THE DATA MOVE?



Independent presentation redesign based on publicly available KPMG Future of SOX webcast material.
Not commissioned by or affiliated with KPMG.